

PONTIFÍCIA UNIVERSIDADE CATÓLICA DE MINAS GERAIS
SISTEMAS DE INFORMAÇÃO

Rede Hospitalar Cuidar

*Política de Segurança da Informação (PSI) e Diretrizes de
Infraestrutura*

Grupo de Trabalho:

Athos Geraldo Salomon Dolabela da Silveira
Bernardo Elias Renttins Vasconcelos de Sousa
Fabrício Júnio da Silva
Henrique Fadel Carvalho
Igor de Oliveira Martins dos Santos
Pedro Tolentino Gontijo

Belo Horizonte
2026

Política de Segurança da Informação (PSI)

1. Objetivo

Esta Política de Segurança da Informação (PSI) estabelece as diretrizes para proteger a integridade, confidencialidade e disponibilidade (Tríade CIA) dos dados da **Rede Hospitalar Cuidar**. O foco central é o ambiente de aplicação back-end (Ubuntu Server 24.04 LTS) e a proteção de dados sensíveis de pacientes, em total conformidade com a Lei Geral de Proteção de Dados (LGPD).

2. Mecanismos de Proteção e Infraestrutura de Rede

- **Subdivisão de Rede (CIDR e NAT):** A infraestrutura foi planejada com otimização rigorosa de endereçamento. Utilizando técnicas de CIDR, as sub-redes foram acondicionadas para limitar os domínios de *broadcast* e segmentar o tráfego. O acesso externo é gerenciado por NAT (*Overload/PAT*), garantindo que a topologia interna permaneça protegida contra varreduras externas.
- **Acesso em Nuvem Criptografado:** O acesso ao servidor de aplicação (IP 192.168.18.75) é estritamente realizado via SSH utilizando autenticação por chaves assimétricas (pública e privada). A autenticação por senha está permanentemente desativada no arquivo `sshd_config`, impossibilitando ataques de força bruta.
- **Automação e DevOps (CI/CD):** O servidor back-end (Python 3.12 + Flask 3.0.3) opera sob um pipeline de Integração e Entrega Contínuas. O *deploy* é automatizado, contando com recursos preparados para escalonamento horizontal e alta disponibilidade.

3. Identificação e Mitigação de Vulnerabilidades

Ferramentas de análise identificaram riscos críticos de *Broken Access Control* (OWASP) na porta 5000 do servidor. Diferente de uma postura passiva, a equipe técnica descreveu e implementou as seguintes soluções de atenuação:

- **Implementação de RBAC e Sessão:** O *endpoint* vulnerável foi mitigado por meio da implementação da biblioteca *Flask-Login*, exigindo credenciais por perfil de acesso (Médico, Recepção, TI), integrados ao Active Directory corporativo (`minasgerais.net`).
- **Mitigação de Rede (UFW):** O *Uncomplicated Firewall* (UFW) foi ativado no Ubuntu Server, restringindo o acesso à porta 5000 estritamente aos IPs autorizados da rede interna.

4. Projeções de Melhoria Contínua

A segurança será tratada como um processo iterativo. Trimestralmente, a infraestrutura passará por auditorias automatizadas de código e testes de intrusão (*Pentests*).